

SecureVoteMultiSig

SecureVoteMultiSig.sol | Solidity ^0.8.20 | OWASP SC Top 10 2026 + SWC Registry

82

RISK SCORE / 100

1. Identificacion del contrato

Proposito	Multisig: varios owners aprueban un txHash y, alcanzado el umbral required, se ejecuta una transferencia.
Actores	Owners (approve), cualquiera (execute).
Flujo de fondos	execute() envia value ETH a to si hay suficientes aprobaciones de owners para txHash.

2-4. Hallazgos: clasificacion OWASP / SWC y vector de ataque

#	Riesgo / Causa raiz	Descripcion y vector de ataque	Sev.	SWC	OWASP 2026
1	txHash no vinculado a (to, value) Root: Desacople entre la autorizacion (hash) y los parametros reales de la accion.	execute(to, value, txHash) no comprueba que txHash == hash(to,value,...). Los owners aprueban un hash abstracto pero execute admite cualquier destino e importe mientras ese hash tenga aprobaciones. Vector: Con un txHash que ya reune 'required' aprobaciones, el atacante ejecuta una transferencia a su address por el importe que quiera.	Critical	SWC-121	SC02:2026 Business Logic Errors
2	Sin marca de ejecutado: replay Root: Falta proteccion anti-replay/nonce por transaccion.	No existe un flag executed[txHash]; execute() puede llamarse repetidamente con el mismo txHash aprobado. Vector: Replay: vaciar el contrato repitiendo execute() hasta agotar el balance.	Critical	SWC-121	SC02:2026 Business Logic Errors
3	required y owners sin validacion Root: Constructor sin invariantes de configuracion.	No se valida required>0, required<=owners.length ni unicidad de owners; required=0 permite ejecutar sin aprobaciones. Vector: Configuracion degenerada que anula el umbral del multisig.	Medium	SWC-123	SC05:2026 Lack of Input Validation

3. Analisis de logica de negocio

Pese al nombre 'Secure', el multisig no ata la aprobacion al contenido de la transaccion ni evita la repeticion, por lo que no ofrece seguridad real.

6. Benchmark metrics

3	2	0	1	0	0.90	0.88	1.00	65	82
Total	Critical	High	Medium	Low	Confidence	Precision	Coverage	Time (s)	Risk

Severidad: Critical / High / Medium / Low. Metricas Precision/Coverage/Confidence estimadas (0-1). Risk score agregado por severidad (0-100). Analisis estatico manual; sin ground truth provisto (Gold Standard: N/A).